PROYECTO ACADÉMICO DE CIBERSEGURIDAD

Detección y prevención de fuga de información en un endpoint Windows

Arquitectura del sistema, casos de uso
y evaluación experimental de controles DLP

Implementación local Windows / Node.js / PowerShell

Versión del sistema: 2.0.0

Octubre de 2026

Datos ficticios, escenarios autorizados y límites de cobertura explícitos

Resumen e índice

Se implementó un laboratorio de prevención de fuga de información (DLP) en Windows. El sistema clasifica archivos locales, vigila carpetas configuradas y aplica políticas antes de ejecutar transferencias mediadas. Un complemento extiende el control a interacciones soportadas del navegador; un sensor nativo observa portapapeles, dispositivos e impresión. Se conservó el portal Windows/Kali como canal adicional.

La evaluación utiliza 27 documentos ficticios y 135 operaciones en cinco canales. Distingue sensibilidad detectada de una restricción por extracción incompleta, y separa una decisión de política de la evidencia de su ejecución. La impresión virtual se verificó con Windows. Los resultados describen un prototipo académico, no protección selectiva universal de toda aplicación o protocolo.

Contenido	Página
1. Requisitos y alcance	3
2. Arquitectura de red	4
3. Componentes y límites de confianza	5
4. Modelo de casos de uso	6
5. Especificación de casos de uso	7
6. Clasificación y políticas	8
7. Flujo de una transferencia	9
8. Secuencia del navegador	10
9. Integración con Windows	11
10. Evaluación multicanal	12
11. Evidencia funcional y nativa	13
12. Instalación y demostración	14
13. Seguridad y limitaciones	15
14. Conclusiones y referencias	16

1. Requisitos y alcance

Consigna. Implementar controles DLP, clasificar información sensible y ejecutar escenarios controlados de transferencia o exfiltración para determinar actividades permitidas, detectadas, alertadas o bloqueadas; evaluar falsos positivos y falsos negativos.

Tabla 1. Trazabilidad de la consigna a funciones verificables

Requisito	Implementación y comprobación
Clasificar información sensible	Once reglas compartidas; lectura de texto, PDF, DOCX y XLSX. Inventario local y reclasificación antes de transferir.
PERMITIDO	Documento sin coincidencias, inspección completa y operación habilitada. Se contrasta con bytes recibidos o escritos.
DETECTADO	Modo audit: existe coincidencia pero se permite la operación. La vigilancia de carpetas es detección, no bloqueo de copias.
ALERTA	Modo alert o puntaje inferior al umbral: se registra la observación y se permite la operación.
BLOQUEADO	El camino mediado no invoca el adaptador; el conector retiene la interacción soportada. Se verifica el destino por separado.
Falsos positivos / negativos	Etiquetas de referencia declaradas por propósito del caso; matrices separadas para detección y prevención.

Delimitación del término endpoint

El agente funciona en la sesión del usuario y fuera del portal. No instala un filtro de sistema de archivos, controlador de red ni protección antimanipulación. La prevención selectiva se limita a caminos mediados y al conector; los controles generales opcionales de Windows afectan todo el canal. No se presenta este diseño como un antivirus ni como detector universal de archivos maliciosos.

2. Arquitectura de red

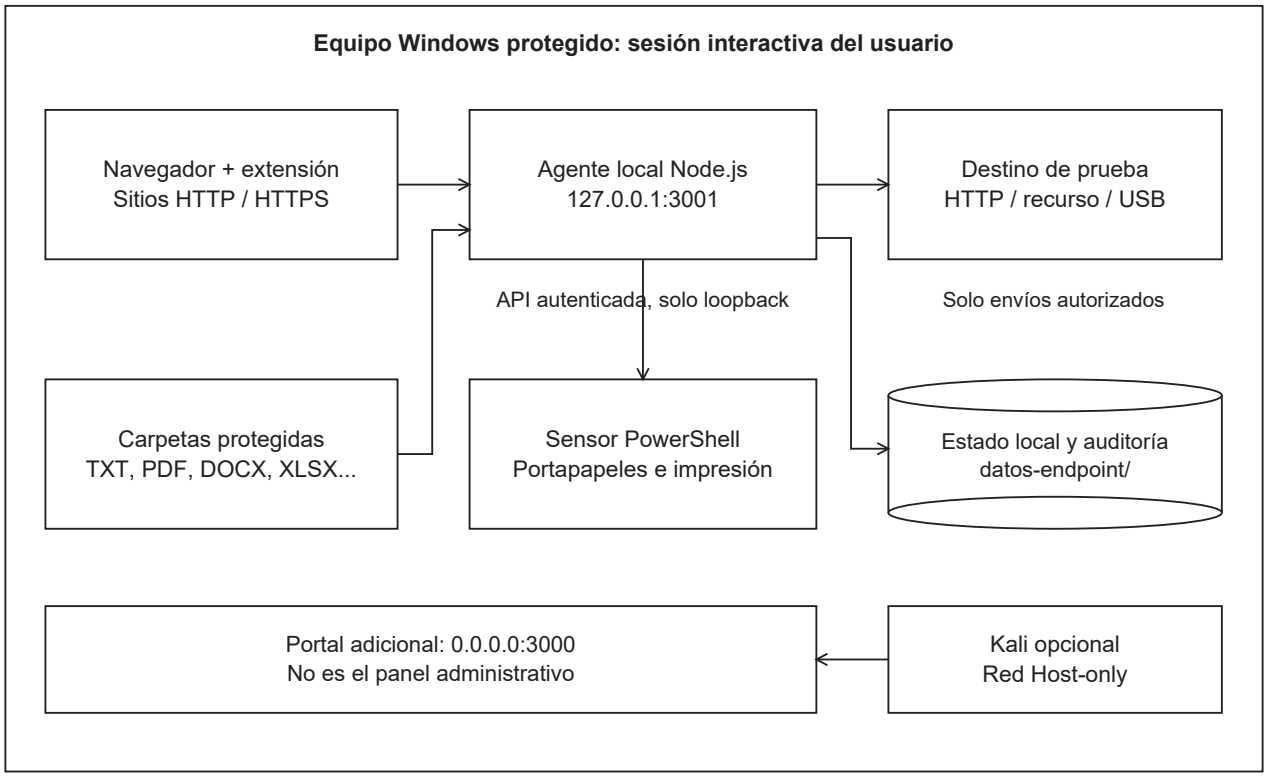


Figura 1. Despliegue local y canal adicional Windows/Kali.

Nota. El agente administrativo permanece en loopback. Las flechas describen comunicación o lectura, no cobertura universal. Elaboración a partir del código del proyecto [1].

Tabla 2. Superficies de red de la demostración

Servicio	Dirección predeterminada	Finalidad
Agente y panel	127.0.0.1:3001	Administrar inventario, políticas y auditoría; consulta del complemento.
Portal histórico	0.0.0.0:3000	Pruebas desde Windows/Kali. No exponer a Internet.
Receptor HTTP	127.0.0.1:4100	Recibir bytes de transferencias permitidas.
Sitio independiente	127.0.0.1:4200	Demostrar que el control proviene del complemento y no del destino.

Kali es opcional. En Host-only utiliza la IP de Windows para el puerto 3000, no localhost. La dirección 192.168.56.1 corresponde a la configuración previa del laboratorio y debe verificarse en cada equipo. Un receptor en Kali puede configurarse como destino autorizado sin publicar el panel 3001.

3. Componentes y límites de confianza

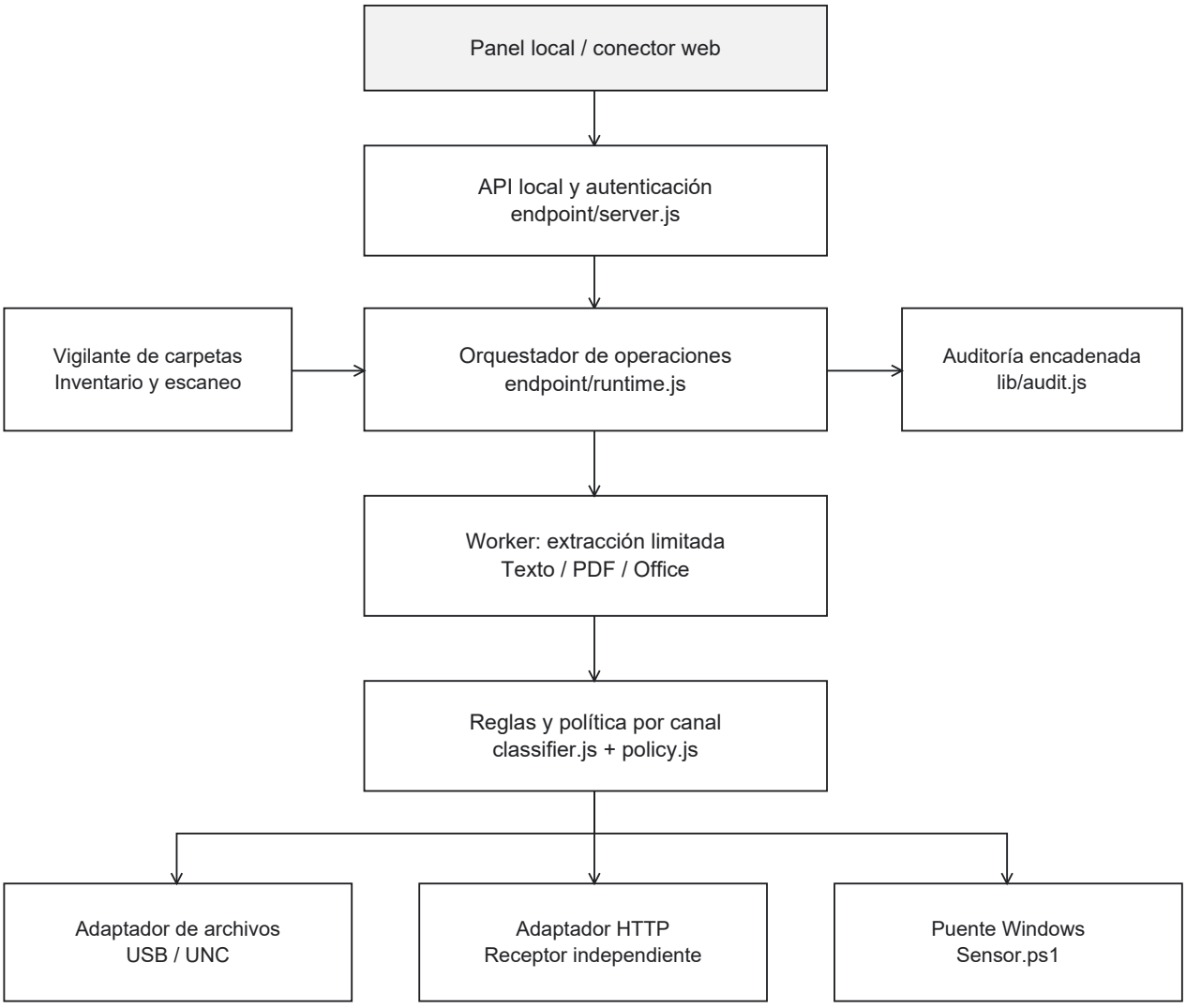


Figura 2. Separación entre orquestación, extracción, decisión y ejecución.

Nota. La política se evalúa antes del adaptador. Los workers acotan recursos, pero no son una sandbox de seguridad equivalente a una máquina virtual. Fuente: endpoint/ y lib/ [1].

El panel utiliza un token administrativo; el conector dispone de un token distinto y restringido a inspección y resultados. El agente valida Host y origen, limita entradas y concurrencia. El contenido se procesa localmente y no se remite a servicios de IA. El receptor de laboratorio no constituye un servicio de producción autenticado.

La lectura produce una instantánea de bytes: esa misma instantánea se clasifica y, si procede, se transfiere. No se utiliza como autorización un puntaje almacenado previamente en el inventario. El registro incluye hash, reglas, decisión y tipo de evidencia, no una copia completa del documento.

4. Modelo de casos de uso

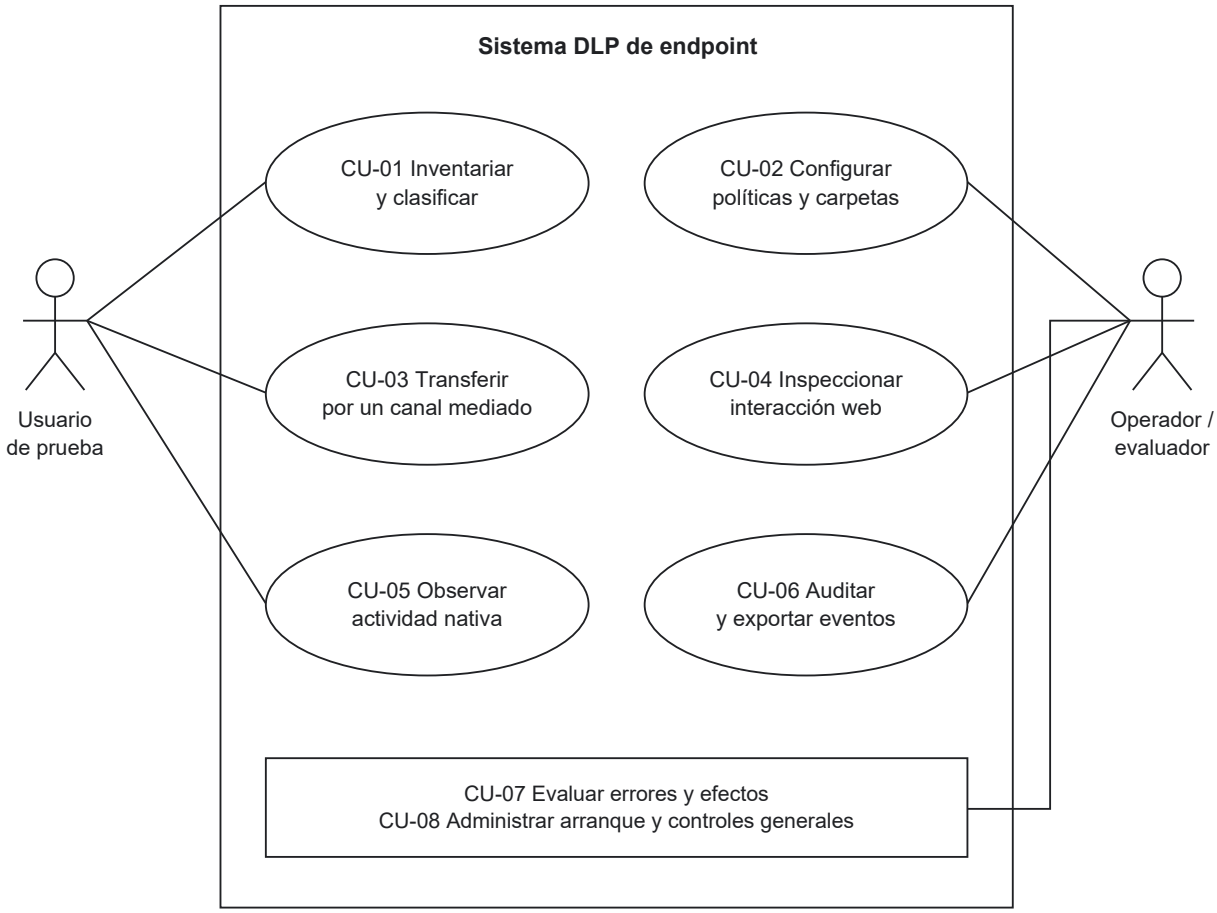


Figura 3. Funciones del usuario de prueba y del operador/evaluador.

Nota. Los actores son responsabilidades de uso, no roles multiusuario con permisos empresariales. El mantenimiento de políticas generales exige privilegios administrativos [1].

Tabla 3. Responsabilidades de los participantes

Actor	Responsabilidad
Usuario de prueba	Trabajar con documentos ficticios y ejecutar operaciones permitidas por los caminos cubiertos.
Operador / evaluador	Configurar raíces y destinos, revisar eventos, ejecutar baterías y contrastar evidencias.
Windows / navegador / destino	Sistemas colaboradores: exponen eventos, ejecutan efectos o aportan recibos independientes.

CU-08 no se activa de forma automática: instalar arranque o políticas generales requiere una decisión explícita del operador. El conjunto de casos de uso evita confundir una notificación posterior al hecho con la cancelación de una transferencia.

5. Especificación de casos de uso

Tabla 4. Contratos funcionales y alternativas relevantes

Caso	Precondición, flujo y resultado
CU-01 Inventariar	Raíz accesible configurada. Recorrer archivos, extraer texto, clasificar y registrar hash/estado. Un cambio observado programa un nuevo escaneo. Si se alcanza el límite o faltan permisos se declara cobertura incompleta.
CU-02 Configurar	Panel local autenticado. Validar JSON de carpetas, modos y destinos; guardar y reconfigurar vigilantes. No permite usar el token del navegador para administrar.
CU-03 Transferir	Archivo inventariado y destino habilitado. Volver a leer y clasificar; registrar decisión. Si se deniega, no ejecutar el adaptador. Si se permite, registrar PREPARED y después COMPLETED o FAILED.
CU-04 Interacción web	Complemento activo, página cubierta y token emparejado. Retener selección/pegado/arrastre; consultar al agente; liberar o cancelar; reportar resultado. Un ticket de decisión no prueba recepción en el destino.
CU-05 Observar Windows	Sesión interactiva y sensor disponible. Detectar portapapeles después de copiar y metadatos de trabajos externos. No atribuir bloqueo previo. La limpieza opcional se registra como remediación reactiva.
CU-06 Auditar	Leer decisiones y resultados, comprobar cadena SHA-256 y exportar CSV. Una cadena alterada impide nuevas operaciones que requieren registro previo. No equivale a firma digital.
CU-07 Evaluar	Crear datos ficticios etiquetados; ejecutar canales y contrastar recibos, archivos y hashes. Calcular VP, FP, VN y FN, conservando los casos que fallan.
CU-08 Administrar	Consultar Plan sin cambios. Instalar arranque voluntario o aplicar/restaurar controles generales como administrador. Conservar respaldo y verificar el efecto en dispositivos propios.

6. Clasificación y políticas

Cada regla coincidente aporta sus puntos una sola vez por archivo. El puntaje es un criterio de política, no una probabilidad de privacidad. No se verifica identidad contra un padrón ni se comprende todo contexto semántico. Un dato puede ser privado aunque ninguna regla lo reconozca.

Tabla 5. Reglas DLP-001 a DLP-011 de lib/classifier.js

Regla	Indicador	Puntos
001	Campo de clasificación confidencial	3
002	Campo de clasificación restringida	5
003	Código de estudiante de ocho dígitos	2
004	Nota final entre 0 y 20	2
005	Correo del dominio ficticio universidad.edu.pe	1
006	Etiqueta de contraseña temporal	3
007	Nombre de estudiante y calificación final en texto	3
008	Campo DNI con ocho dígitos	3
009	Campo de contraseña, secreto o token	4
010	Secuencia de tarjeta que satisface Luhn	5
011	Etiqueta de diagnóstico o historia clínica	3

Tabla 6. Política independiente por canal

Modo	Efecto ante coincidencia
audit	DETECTADO: permite y registra.
alert	ALERTA: permite y registra.
enforce	Bloquea al alcanzar blockScore; por defecto 3. Con 1-2 alerta; con 0 permite si la extracción es completa.

Una extracción parcial o no analizable se retiene en enforce incluso con puntaje cero. No se etiqueta como sensibilidad reconocida. En audit/alert puede permitirse con advertencia. Un JSON con código de estudiante y nota suma cuatro puntos aunque no incluya la palabra confidencial.

7. Flujo de una transferencia

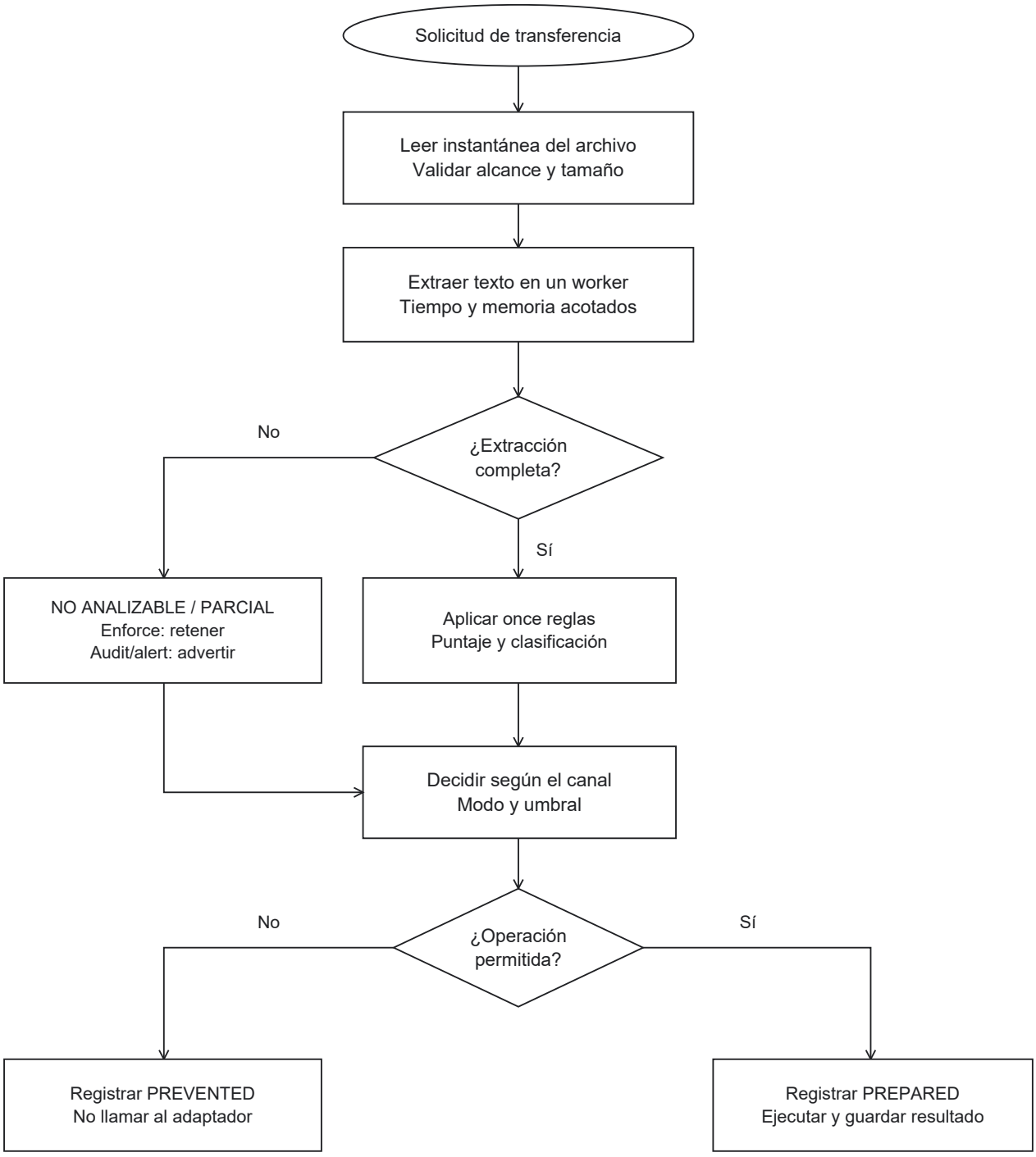


Figura 4. Validación, clasificación y ejecución condicional.

Nota. La falta de extracción completa es un estado explícito. El resultado de política se conserva separado del resultado operativo. Fuente: EndpointRuntime.transfer y decide [1].

Los fallos del adaptador producen FAILED/ERROR, no una transferencia completada ni un bloqueo por contenido. El agente no conserva los bytes sensibles en el registro de auditoría; puede conservar rutas, nombres y metadatos que también deben protegerse.

8. Secuencia del navegador

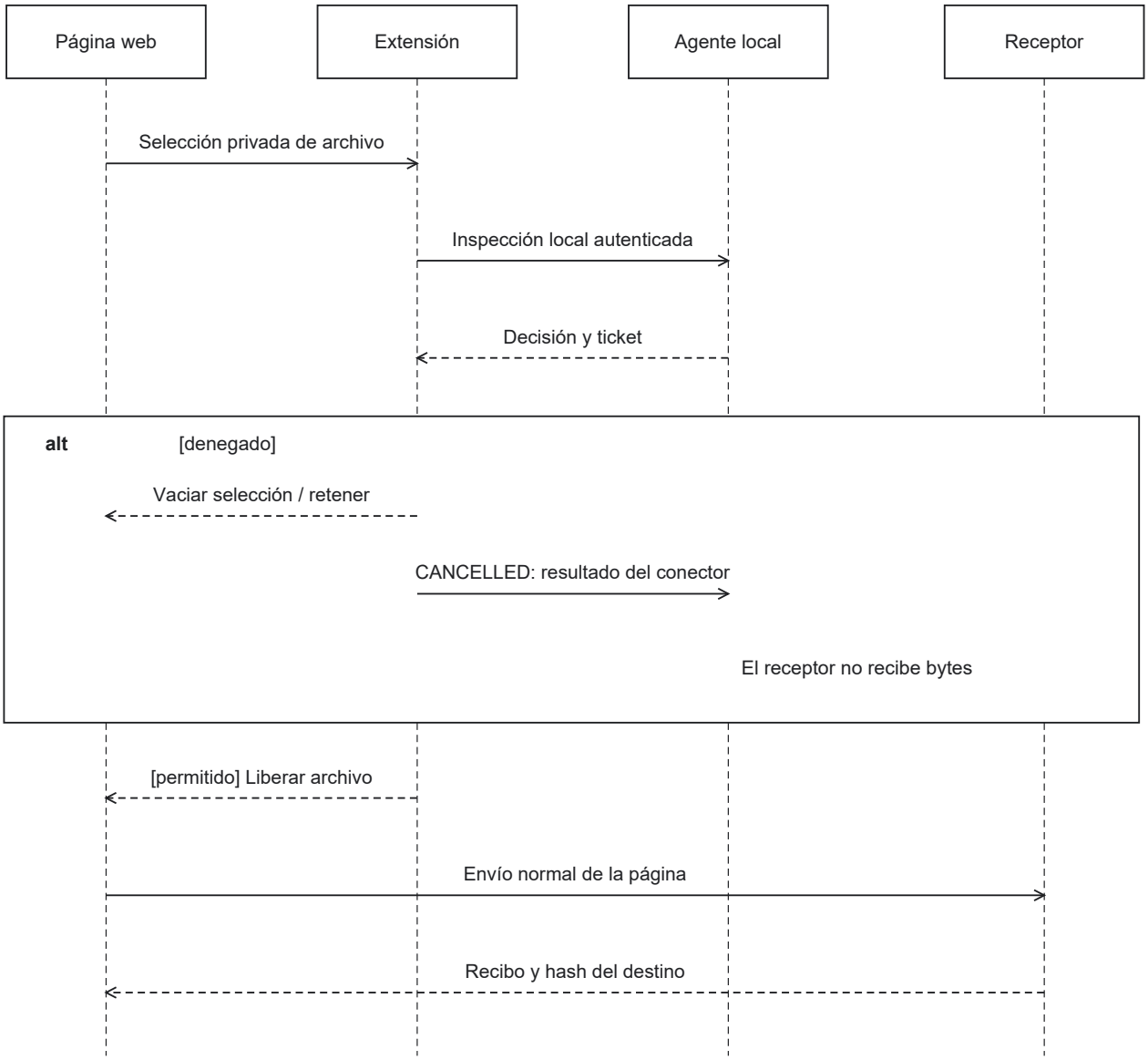


Figura 5. Retención por el conector y verificación independiente de recepción.

Nota. CANCELLED es un reporte del cliente. La batería contrasta adicionalmente que el receptor no recibió bytes; el complemento no conoce todas las APIs o aplicaciones [1, 5].

Alcance del punto de control

La selección interceptada utiliza un selector privado antes de entregar archivos al DOM de la página. El pegado de texto y el arrastre se inspeccionan y se reemiten si se permiten. La secuencia soportada puede interrumpirse si la página exige eventos de confianza o emplea mecanismos distintos.

Al desactivar una extensión no administrada se pierde este control. La demostración incluye ese control negativo y la indisponibilidad del agente. Las pruebas automatizadas de pegado y arrastre emplean eventos sintéticos: no certifican el portapapeles físico ni cada implementación de una página web.

9. Integración con Windows

Tabla 7. Cobertura del endpoint y tipos de control

Canal	Control implementado	Límite de la afirmación
Archivos locales	Vigilante y escaneo de carpetas configuradas.	Detecta contenido y cambios; no intercepta cualquier lectura/copia del Explorador.
USB / SMB	Escritura mediada con política previa; verificación de destino real cuando lab=false.	La batería usa directorios, no acredita hardware USB ni sesión SMB real.
Portapapeles	Copia mediada, observación posterior y limpieza reactiva opcional.	Observar/limpiar después no demuestra prevención global de lectura.
Impresión	Decisión previa al PrintDocument del agente; observación de metadatos externos.	No se clasifica el contenido de cualquier trabajo de otra aplicación.
Políticas generales	Solo lectura USB; bloqueo de puertos SMB; Spooler detenido/deshabilitado.	Afectan datos públicos y sensibles. Deben aplicarse y comprobarse aparte.

Activación, reversión y segundo plano

System-Controls.ps1 utiliza Plan por defecto, sin modificar Windows. Apply/Restore requieren administrador. Conserva estados previos y reglas propias identificadas; la restauración evita sobrescribir cambios que reconoce como ajenos. Reconexión o reinicio puede ser necesario para USB. El bloqueo SMB tradicional no cubre SMB sobre QUIC [4].

Install-Agent.ps1 ofrece Plan, Install y Uninstall para el inicio de sesión del usuario actual. No instala un controlador ni servicio privilegiado. La bandeja permite abrir el panel o detener el proceso. Estos mecanismos no impiden que un usuario con permisos cierre o modifique el agente.

10. Evaluación multicanal

La batería contiene 27 documentos ficticios: diez públicos, quince sensibles y dos no analizables, uno público y otro privado. Los mismos documentos se repiten en cinco canales: 135 operaciones. No son 135 documentos independientes. Las etiquetas se fijan por propósito y contenido; el conjunto es de desarrollo, no una prueba reservada de generalización.

Detección positiva exige una coincidencia de sensibilidad. Prevención positiva exige impedir la operación. Las métricas integrales incluyen los dos documentos sin extracción completa, mientras la segunda lectura restringe el cálculo a los 25 documentos completamente inspeccionados.

Tabla 8. Matrices por canal, con la política predeterminada

Lectura	VP	FP	VN	FN	Precisión	Recall
Detección integral (27)	13	3	8	3	81.25 %	81.25 %
Prevención integral (27)	13	3	8	3	81.25 %	81.25 %
Detección completa (25)	13	3	7	2	81.25 %	86.67 %
Prevención completa (25)	12	2	8	3	85.71 %	80.00 %

Los cinco canales comparten decisiones y por eso presentan las mismas matrices; su evidencia operativa es distinta. Precisión = VP / (VP + FP); recall = VP / (VP + FN). Estos porcentajes no son garantía de protección ni de reconocimiento contextual.

Tabla 9. Naturaleza de la evidencia en las 135 operaciones

Evidencia	Canales
Escritura real en directorios de laboratorio	USB y carpeta compartida; no prueba física.
Receptor HTTP loopback independiente	Envío real y comprobación de hash.
Doble de prueba del adaptador nativo	Portapapeles e impresión de la batería multicanal.

P07/P08/P09 producen falsos positivos de detección: ejemplo didáctico, correo público y tarjeta de prueba. S14/S15 no activan reglas pese a ser privados. S13 se detecta pero se permite. El cierre conservador de U01/U02 modifica prevención sin demostrar comprensión de contenido.

11. Evidencia funcional y nativa

La batería de software pasó 32 pruebas: portal, extracción de seis formatos, límites, política, inventario, vigilancia de una creación sin carga web, transferencias, autenticación/orígenes, separación de tokens, resultados del navegador e integridad de auditoría. Una prueba exitosa valida su aserción concreta, no todo comportamiento posible.

Tabla 10. Evidencia adicional a los dobles de prueba

Comprobación Windows	Resultado observado
Sensor en sesión interactiva	Disponible; tres impresoras instaladas; ningún dispositivo extraíble conectado.
Documento sensible / Print to PDF	Bloqueado antes del adaptador nativo; cero llamadas de impresión para ese documento.
Documento público / Print to PDF	PDF real generado por el controlador Windows; cabecera PDF y archivo no vacío verificados.
Modificaciones generales	No se alteraron políticas USB/SMB/Spooler ni el portapapeles del usuario para esta prueba.

Prueba del complemento en navegador

La batería se ejecutó con Chromium 151.0.7922.34 en un perfil aislado y completó 8 escenarios. Comprobó selección sensible/pública, pegado sensible/público, arrastre sensible/público, complemento desactivado y agente fuera de línea.

El receptor independiente recibió únicamente los contenidos liberados, salvo en el control negativo con el complemento desactivado, donde recibió el sensible ficticio. La selección usa el selector del navegador; pegado y arrastre usan eventos DOM sintéticos. No se afirma una prueba de todas las páginas ni de Firefox.

Archivos de evidencia: output/evaluacion/resultado-endpoint.json, resultado-windows.json y resultado-navegador.json. Los resultados incluyen fecha y alcance; no se sustituyen por capturas de una interfaz que solo declara estar activa.

12. Instalación y demostración

Requisitos y arranque

Windows 10/11, Node.js 24 o superior y PowerShell 5.1 en sesión interactiva. Git es opcional con ZIP. Instalar dependencias con npm.cmd ci, generar la extensión con npm.cmd run extension:build y ejecutar npm.cmd start. Abrir http://127.0.0.1:3001. No se necesitan Ubuntu, base de datos ni API de pago.

1. Mostrar inventario y crear un TXT ficticio en laboratorio/protegidos/. Esperar al vigilante sin cargarlo al portal.

2. Transferir un público y un sensible a un destino de laboratorio; comprobar físicamente la carpeta de salida.

3. Ejecutar npm.cmd run receiver y repetir contra HTTP; revisar recibos y hashes, no solo la decisión del panel.

4. Emparejar el complemento desde la sección Navegador. Ejecutar npm.cmd run site:demo y abrir el puerto 4200. Comparar conector activo/desactivado.

5. Imprimir mediante Microsoft Print to PDF y comprobar que solo el público produce un archivo. Revisar eventos de prevención y ejecución.

6. Ejecutar npm.cmd test, npm.cmd run evaluate:endpoint y npm.cmd run test:windows. Explicar los errores de clasificación encontrados.

Comprobaciones físicas posteriores

Para USB real, conectar una unidad propia, confirmar tipo extraíble, configurar lab=false y contrastar escritura pública/bloqueo sensible por el agente. Para SMB, preparar un recurso UNC autorizado y verificar sus archivos desde el servidor. Si se desea bloquear copias nativas del canal completo, revisar y aplicar las políticas generales en una máquina de laboratorio, luego restaurarlas.

La prueba física no debe sustituirse por un destino local renombrado USB. Conservar evidencias del destino, configuración aplicada y resultado; no afirmar eficacia de una política solo porque el script terminó sin error.

13. Seguridad y limitaciones

Tabla 11. Riesgos y límites de las conclusiones

Aspecto	Tratamiento y limitación residual
Privacidad	Clasificación local; sin LLM externo. Inventario y eventos conservan nombres/rutas y deben protegerse con permisos del usuario.
Integridad	Cadena SHA-256 y verificación antes de nuevas escrituras de auditoría. No es firma ni protección ante reconstrucción completa por un administrador.
Archivos hostiles	Lectura limitada y worker sin ejecución intencional de documentos/macros. Las bibliotecas tienen superficie de ataque; no se garantiza ausencia de explotación o malware.
Extracción incompleta	PDF escaneado, cifrado, formato desconocido, límites o errores producen estado explícito. Enforce retiene por no inspección; no se contabiliza como detección sensible.
Cobertura de equipo	Raíces configuradas y accesibles, no todos los discos/usuarios. Sin filtro kernel, control universal de llamadas de red ni protección frente a evasión administrativa.
Navegador	Extensión no administrada y flujos DOM soportados. Puede desactivarse; aplicaciones y APIs no interceptadas quedan fuera.
Disponibilidad	Cierre conservador puede bloquear material público. El fallo del sensor o destino se informa, no se transforma en éxito.
Modelo de clasificación	Reglas explicables pero frágiles a contexto, reformulación u ocultación. Los resultados de desarrollo no estiman todo documento futuro.

Un DLP empresarial puede incorporar controles de endpoint administrados, identidad, políticas centralizadas y puntos de interceptación adicionales. Microsoft documenta actividades de endpoint diferenciadas [2]; los filtros del sistema de archivos constituyen otra clase de integración [3]. Su existencia no permite atribuir esas capacidades a este prototipo.

14. Conclusiones y referencias

La implementación aborda la consigna mediante clasificación y escenarios controlados que distinguen permiso, detección, alerta y bloqueo. Amplía el portal a un agente local con vigilancia de carpetas, políticas por canal, conector web y sensor Windows. La evidencia verifica efectos concretos y conserva falsos positivos y negativos, en lugar de presentar el sistema como infalible.

La prevención selectiva está demostrada en caminos mediados y, si consta su batería final, en las interacciones probadas del complemento. La impresión virtual tiene evidencia nativa. No se acreditan USB/SMB físicos inexistentes durante la prueba, prevención global del portapapeles ni intercepción universal de aplicaciones. Las políticas generales permanecen opcionales y requieren comprobación separada.

[1] Proyecto DLP. (2026). *Implementación endpoint, pruebas y resultados* [Código y materiales de desarrollo]. endpoint/, lib/, extension/, test/ y evaluacion/. Repositorio base: https://github.com/Brando-01/DLP. La evidencia de esta ampliación corresponde a los archivos locales de la versión 2.0.0; su publicación debe comprobarse por separado.

[2] Microsoft. (s. f.). *Learn about Endpoint data loss prevention*. Microsoft Learn. https://learn.microsoft.com/en-us/purview/endpoint-dlp-learn-about

[3] Microsoft. (s. f.). *About file system filter drivers*. Microsoft Learn. https://learn.microsoft.com/en-us/windows-hardware/drivers/ifs/about-file-system-filter-drivers

[4] Microsoft. (s. f.). *Policy CSP - ADMX_RemovableStorage*. Microsoft Learn. https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-admx-removablestorage

[5] Google. (s. f.). *Content scripts*. Chrome for Developers. https://developer.chrome.com/docs/extensions/develop/concepts/content-scripts

[6] Mozilla. (s. f.). *PDF.js: Getting started*. https://mozilla.github.io/pdf.js/getting_started/

Documentación elaborada en octubre de 2026. Fuentes técnicas consultadas durante la implementación. Todas las figuras son diagramas vectoriales construidos a partir del diseño y código; no representan certificación de un tercero.